SEC-04 - Data Security and Residency Policy

Status: CURRENT

Effective: 2026-08-01 **Owner:** Security Engineering **Version:** 4.0

This synthetic policy governs the document-processor workload and supersedes SEC-03. Where this policy conflicts with older security documents, SEC-04 controls.

1. Data classes

Class	Meaning	Residency / handling
Public	Publicly releasable information	No special residency rule
Internal	Ordinary company information	Default data plane may be ap-south-1
Restricted-EU	EU customer document content	Data plane must be eu-central-1; no cross-region document-content copies

2. Residency rules

Rule	Requirement
2.1 Restricted-EU storage	S3, RDS, backups, and other persistent stores containing Restricted-EU document content must be in eu-central-1.
2.2 Restricted-EU processing	Compute that processes Restricted-EU document content must run in the eu-central-1 data plane.
2.3 Control plane	Metadata with no document content may remain in ap-south-1.
2.4 Cross-region copies	Do not replicate or export Restricted-EU document content to another region.

3. Database network rules

Environment	RDS public access	Notes
Production	PROHIBITED	RDS must use private subnets and private security-group ingress only.
Sandbox	PROHIBITED	No public database endpoint.
Staging	Normally prohibited	A temporary exception may be used only under ADR-004 and all documented conditions.

4. Encryption

All customer document storage must use encryption at rest. Restricted-EU document content must use a customer-managed KMS key. All API, worker, database, and AWS API traffic must use TLS where the protocol supports it.

5. Exception handling

ADR-004 provides a narrowly scoped staging exception for a legacy partner. The exception does not waive encryption or residency requirements and cannot be generalized to production.

Footnote 1: The general region matrix in the platform handbook must be read together with its Restricted-EU footnote; the default ap-south-1 region is not an authorization to process Restricted-EU document content there.

Footnote 2: Observed infrastructure state does not by itself change policy. A detected configuration mismatch must be reconciled through the service owner and Platform Engineering.